

MASTER SERVICES AGREEMENT FOR SECURITY ASSESSMENT SERVICES

AGREEMENT DATE: November 3, 2025

BETWEEN:

APEX PHARMACEUTICALS LLC ("Client" or "Apex") 1847 BioScience Boulevard Cambridge, Massachusetts 02142

AND:

CYBERSHIELD SECURITY CONSULTANTS LTD. ("Consultant" or "CyberShield") 9200 Cyber Defense Plaza, Suite 1800 Austin, Texas 78701

1. PARTIES AND REPRESENTATIVES

1.1 Client Contacts

Primary Security Contact: Dr. Elena Vásquez, Chief Information Security Officer Email: e.vasquez@apexpharma.com Phone: +1 (617) 555-0147 Emergency: +1 (617) 555-0199

Secondary Security Contact: Marcus Chen, Director of IT Security Operations Email: m.chen@apexpharma.com Phone: +1 (617) 555-0148

Legal Contact: Jennifer Park, General Counsel Email: legal@apexpharma.com Phone: +1 (617) 555-0100

1.2 Consultant Contacts

Primary Engagement Manager: Sarah Mitchell, Senior Security Practice Lead Email: s.mitchell@cybershield-sec.com Phone: +1 (512) 555-0234 Emergency: +1 (512) 555-0299

Technical Lead: David Rodriguez, Principal Security Consultant Email: d.rodriguez@cybershield-sec.com Phone: +1 (512) 555-0235

2. SCOPE OF SERVICES

2.1 Quarterly External Penetration Testing

Consultant shall conduct external penetration testing against Client's internet-facing infrastructure four (4) times per calendar year, scheduled as follows:

Testing Schedule:

- Q1: January 15-31
- Q2: April 15-30
- Q3: July 15-31
- Q4: October 15-31

Scope Includes:

- External network perimeter testing of all public IP ranges
- Web application penetration testing (OWASP Top 10 methodology)
- Email security testing (SPF, DKIM, DMARC validation)
- DNS and subdomain enumeration
- SSL/TLS configuration assessment
- Public cloud infrastructure review (AWS, Azure environments)
- External API endpoint security testing
- VPN gateway security assessment

2.2 Annual Internal Network Assessment

Consultant shall conduct one (1) comprehensive internal network security assessment per calendar year during the month of March, with duration of fifteen (15) consecutive business days.

Scope Includes:

- Internal network vulnerability scanning
- Active Directory security assessment
- Wireless network penetration testing
- Physical security testing (with prior written approval)
- Internal web application testing
- Database security configuration review (non-production only)
- Privilege escalation testing
- Lateral movement simulation
- Network segmentation validation

2.3 Social Engineering and Phishing Campaigns

Consultant shall conduct two (2) social engineering campaigns per calendar year:

Campaign 1: February (email phishing simulation) **Campaign 2:** September (multi-vector campaign: email, phone, and physical)

Scope Includes:

- Customized phishing email templates
- Credential harvesting simulation (safe capture only)
- Telephone-based social engineering (vishing)
- Physical access attempt simulation (with 48-hour advance notice)
- Executive targeting simulation
- Awareness training recommendations
- Detailed user behavior metrics

2.4 Web Application Security Testing

Consultant shall perform security assessments on up to six (6) web applications per quarter as designated by Client, with minimum two (2) weeks advance notice.

Testing Methodology:

- Manual penetration testing using OWASP Testing Guide
- Automated vulnerability scanning (coordinated timing)
- Authentication and session management testing
- Business logic flaw identification
- API security testing
- Input validation and injection testing
- Client-side security assessment

3. FACILITY LOCATIONS AND IP RANGES

3.1 Research Facilities Subject to Assessment

- 1. Cambridge Research Campus** (Headquarters)
 - 1847 BioScience Boulevard, Cambridge, MA 02142
 - IP Range: 203.45.128.0/24
 - Production Database: apex-prod-cam-01.internal
- 2. San Diego Discovery Center**
 - 4201 Torrey Pines Road, San Diego, CA 92037
 - IP Range: 203.45.129.0/24
 - Production Database: apex-prod-sd-01.internal
- 3. Research Triangle Facility**
 - 850 Biotech Drive, Durham, NC 27703
 - IP Range: 203.45.130.0/24
 - Production Database: apex-prod-rtp-01.internal
- 4. Basel European Operations**
 - Grenzacherstrasse 487, Basel, Switzerland 4058
 - IP Range: 185.92.45.0/24
 - Production Database: apex-prod-basel-01.internal
- 5. Singapore Innovation Hub**
 - 11 Biopolis Way, #08-01, Singapore 138667
 - IP Range: 202.156.78.0/24
 - Production Database: apex-prod-sg-01.internal
- 6. Boston Clinical Research Center**
 - 275 Grove Street, Boston, MA 02215
 - IP Range: 203.45.131.0/24
 - Production Database: apex-prod-bos-01.internal
- 7. South San Francisco Laboratory**
 - 333 Oyster Point Boulevard, South San Francisco, CA 94080
 - IP Range: 203.45.132.0/24
 - Production Database: apex-prod-ssf-01.internal
- 8. Seattle Biomanufacturing Plant**
 - 1201 Eastlake Avenue East, Seattle, WA 98102
 - IP Range: 203.45.133.0/24
 - Production Database: apex-prod-sea-01.internal
- 9. Philadelphia Drug Development Center**
 - 3535 Market Street, Philadelphia, PA 19104
 - IP Range: 203.45.134.0/24
 - Production Database: apex-prod-phl-01.internal

10. Austin Computational Biology Lab

- 1400 Barbara Jordan Boulevard, Austin, TX 78723
- IP Range: 203.45.135.0/24
- Production Database: apex-prod-atx-01.internal

11. London Research Outpost

- 215 Euston Road, London, UK NW1 2BE
- IP Range: 185.92.46.0/24
- Production Database: apex-prod-lon-01.internal

12. Tokyo Collaboration Center

- 1-1-1 Nihonbashi, Chuo-ku, Tokyo 103-0027, Japan
- IP Range: 202.156.79.0/24
- Production Database: apex-prod-tyo-01.internal

3.2 Out-of-Scope Systems

The following systems are **explicitly excluded** from all testing activities:

- All production databases during business hours (Monday-Friday, 6:00 AM - 8:00 PM local facility time)
- Medical device systems directly connected to patient care
- Manufacturing control systems (SCADA/ICS)
- Third-party vendor systems not owned by Client
- Systems labeled "PROD-CRITICAL" in Client's asset inventory
- Backup and disaster recovery systems during backup windows
- Any system added to the exclusion list via written notice 24 hours prior to testing

4. RULES OF ENGAGEMENT

4.1 Testing Windows

External Testing:

- Permitted 24/7 for internet-facing infrastructure
- Automated scanning permitted during off-peak hours only (10:00 PM - 6:00 AM ET)

Internal Testing:

- Monday through Friday, 8:00 AM - 6:00 PM local time only
- No testing on Client-designated holidays
- Production database testing restricted to weekends (Saturday 12:00 AM - Sunday 11:59 PM local time)

4.2 Communication Protocol

Pre-Engagement:

- Consultant shall provide detailed testing plan five (5) business days before commencement
- Client must provide written approval via email from Dr. Vásquez or Marcus Chen
- Kick-off conference call required within 48 hours of testing start

During Engagement:

- Consultant shall provide daily status email by 5:00 PM ET
- Emergency contact: Consultant shall immediately call both Client security contacts for any Critical findings
- Service disruption: Consultant shall cease testing immediately and notify Client within 15 minutes

Post-Engagement:

- Debrief call within two (2) business days of testing completion
- Draft report delivery within five (5) business days
- Final report delivery within ten (10) business days

4.3 Prohibited Activities

Consultant shall NOT engage in the following without explicit written authorization:

- Denial of Service (DoS) or Distributed Denial of Service (DDoS) attacks
- Physical destruction of property
- Social engineering targeting executive leadership (CEO, CFO, CSO) without 48-hour advance notice
- Data exfiltration exceeding 10MB or containing actual regulated data (PHI, PII, PCI)
- Password cracking beyond 24-hour duration
- Exploitation of zero-day vulnerabilities without immediate disclosure
- Testing from locations prohibited by export control regulations
- Any activity that would violate HIPAA, FDA 21 CFR Part 11, or GxP compliance requirements

4.4 Tool Restrictions

Prohibited Tools:

- Metasploit "autopwn" or automated exploitation features
- SQLmap with "--os-shell" or "--sql-shell" flags against production
- Any tools causing kernel panics or system crashes
- Wireless deauthentication attacks during business hours
- ARP spoofing tools in production segments
- Tools generating >1000 requests per second without throttling

Approved Tools (Non-Exhaustive List):

- Nmap (with rate limiting: -T3 or lower)
- Burp Suite Professional
- Metasploit Framework (manual exploitation only)
- Nessus, Qualys, or equivalent vulnerability scanners
- Responder (passive mode only)
- BloodHound (non-disruptive collection)
- Custom scripts subject to pre-approval

5. PERSONNEL REQUIREMENTS

5.1 Background Checks

All Consultant personnel with access to Client systems or facilities must undergo and pass the following background checks:

- **Criminal Background Check:** Federal and state-level, 7-year history
- **Identity Verification:** Government-issued photo ID verification
- **Employment Verification:** Previous two (2) employers
- **Education Verification:** Claimed degrees and certifications
- **Credit Check:** For personnel handling financial systems
- **Social Media Assessment:** Public profile review for security concerns

Background check reports must be provided to Client's General Counsel thirty (30) days prior to engagement start. Client reserves the right to reject any personnel based on background check results.

5.2 Certification Requirements

At least 75% of personnel assigned to each engagement must hold one or more of the following certifications:

- Offensive Security Certified Professional (OSCP)
- Certified Ethical Hacker (CEH)
- GIAC Penetration Tester (GPEN)
- Certified Information Systems Security Professional (CISSP)
- Offensive Security Certified Expert (OSCE)
- Offensive Security Web Expert (OSWE)

The designated Technical Lead for each engagement must hold at least two (2) of the above certifications.

5.3 Personnel Consistency

- Consultant shall assign a consistent team for the duration of this Agreement
- Any personnel changes require written notice ten (10) business days in advance
- Replacement personnel must meet all requirements in Section 5.1 and 5.2
- Maximum of one (1) junior consultant per engagement for training purposes

5.4 Non-Solicitation

During the term of this Agreement and for twelve (12) months thereafter, neither party shall solicit for employment any personnel directly involved in the services provided under this Agreement without prior written consent.

6. REPORTING REQUIREMENTS

6.1 Report Delivery Timeline

Draft Report: Within five (5) business days of testing completion **Client Feedback Period:** Five (5) business days to provide technical corrections **Final Report:** Within ten (10) business days of testing completion (inclusive of feedback period)

Failure to meet these timelines shall result in a 5% reduction in fees for that specific engagement, unless delay is caused by Client's failure to provide timely feedback.

6.2 Report Format and Contents

All reports shall be delivered in the following formats:

- Adobe PDF (encrypted, password-protected)
- Microsoft Word (.docx) format for Client editing
- Spreadsheet (.xlsx) with vulnerability tracking data

Required Report Sections:

1. Executive Summary (maximum 2 pages)

- High-level findings summary
- Risk exposure overview
- Strategic recommendations
- Compliance impact analysis

2. Methodology

- Testing approach and standards followed
- Tools and techniques employed
- Testing timeline and scope
- Limitations and constraints

3. Technical Findings

- Detailed vulnerability descriptions
- Proof-of-concept demonstrations
- Affected systems listing
- CVSS 3.1 scores with vector strings
- CWE classifications

4. Evidence

- Screenshots (sanitized of sensitive data)
- Command outputs
- Network traffic captures (sanitized)
- Exploitation logs

5. Recommendations

- Specific remediation steps
- Prioritization matrix
- Implementation effort estimates
- Compensating controls

6. Appendices

- Scope documentation
- Tool configurations
- Raw scan data (sanitized)
- References and citations

6.3 Severity Classification Schema

All identified vulnerabilities shall be classified using the following schema:

CRITICAL (CVSS 9.0-10.0)

- Unauthenticated remote code execution
- Authentication bypass leading to full system compromise
- SQL injection with data exfiltration capability
- Complete loss of confidentiality, integrity, or availability
- **Reporting SLA:** Immediate verbal notification + written report within 4 hours

HIGH (CVSS 7.0-8.9)

- Authenticated remote code execution
- Privilege escalation to administrative access
- Cross-site scripting with session hijacking capability
- Sensitive data exposure (PII, PHI, financial)
- Significant business impact
- **Reporting SLA:** Notification within 24 hours

MEDIUM (CVSS 4.0-6.9)

- Information disclosure (non-sensitive)
- Cross-site request forgery
- Stored XSS (limited impact)
- Security misconfiguration with exploitation path
- Moderate business impact
- **Reporting SLA:** Included in draft report

LOW (CVSS 0.1-3.9)

- Security best practice violations
- Information leakage (minimal sensitivity)
- Missing security headers
- TLS configuration weaknesses (non-exploitable)
- Minimal business impact
- **Reporting SLA:** Included in final report

INFORMATIONAL (CVSS N/A)

- Observations and recommendations
- Compliance gaps (no direct exploit)
- Hardening opportunities
- **Reporting SLA:** Included in final report

6.4 Vulnerability Tracking

Each vulnerability shall be assigned a unique identifier using the format: **APEX-YYYY-NNNN** (e.g., APEX-2025-0001)

Consultant shall maintain a vulnerability database tracking:

- Initial discovery date
- Current status (Open, In Progress, Resolved, Accepted Risk)
- Remediation verification date
- Re-test results

7. REMEDIATION VERIFICATION TESTING

7.1 Included Re-Testing

For each engagement, Consultant shall provide one (1) round of remediation verification testing at no additional cost, subject to the following conditions:

- Re-test must occur within sixty (60) days of final report delivery
- Client must provide written notice that remediation is complete
- Re-test scope limited to previously identified vulnerabilities
- Re-test report delivered within five (5) business days

7.2 Additional Re-Testing

Additional remediation verification beyond the included round shall be billed at Consultant's then-current hourly rates:

- Senior Consultant: \$325/hour
- Principal Consultant: \$425/hour
- Minimum engagement: 4 hours

7.3 Re-Test Findings

If re-testing reveals:

- **100% remediation:** Issue marked as "Resolved - Verified"
- **Partial remediation:** Issue status updated with remaining exposure
- **No remediation:** Issue remains "Open" with escalation to CISO
- **New vulnerabilities introduced:** Documented separately at no charge

8. FINANCIAL TERMS

8.1 Annual Service Fees

Total Annual Fee: \$487,500.00 USD

Breakdown:

- Quarterly External Penetration Testing (4x): \$240,000 (\$60,000 per quarter)
- Annual Internal Network Assessment (1x): \$125,000
- Social Engineering Campaigns (2x): \$45,000 (\$22,500 per campaign)
- Web Application Security Testing (24 apps): \$72,000 (\$3,000 per app)
- Remediation Verification Testing: Included
- Emergency Response Retainer: \$5,500 (unused hours do not roll over)

8.2 Payment Terms

Per-Engagement Payment Schedule:

For each separate engagement:

- **50% upfront:** Due upon receipt of Statement of Work, payable within fifteen (15) days
- **50% upon completion:** Due upon final report delivery, payable within thirty (30) days

Example for Q1 External Testing (\$60,000):

- Invoice #1: \$30,000 due January 1, 2026
- Invoice #2: \$30,000 due within 30 days of final report delivery

8.3 Payment Methods

- Wire transfer (preferred): Details provided on invoice
- ACH/EFT transfer
- Company check (add 5 business days for processing)

Late Payment: Interest accrues at 1.5% per month (18% annual) on overdue balances exceeding thirty (30) days.

8.4 Expense Reimbursement

The following expenses are included in the fees:

- Personnel travel within continental United States
- Standard testing tools and software licenses
- Report generation and delivery

The following expenses require pre-approval and shall be reimbursed at cost:

- International travel (for Basel, Singapore, London, Tokyo facilities)
- Specialized hardware for testing (e.g., wireless adapters, physical access tools)
- Third-party licenses for Client-specific tools
- Expedited shipping or emergency travel

8.5 Annual Fee Adjustment

Fees shall increase annually by the lesser of:

- 3.5%, OR
- The percentage increase in the U.S. Consumer Price Index (CPI-U) for the preceding 12 months

Fee adjustments take effect on each anniversary of the Agreement Effective Date.

9. LIABILITY AND INDEMNIFICATION

9.1 Liability Cap

Standard Liability Cap: Consultant's total aggregate liability for all claims arising from or related to this Agreement, whether in contract, tort, negligence, or otherwise, shall not exceed an amount equal to two times (2x) the total fees paid by Client in the twelve (12) months preceding the claim.

Current Cap Calculation (Year 1): \$975,000 (2 x \$487,500)

9.2 Carve-Outs from Liability Cap

The liability cap in Section 9.1 shall NOT apply to:

1. **Gross Negligence or Willful Misconduct**
 - Intentional unauthorized access beyond scope
 - Deliberate data destruction or theft
 - Willful violation of Rules of Engagement
 - Fraud or criminal conduct by Consultant personnel
2. **Breach of Confidentiality or NDA**
 - Unauthorized disclosure of Client's confidential information
 - Disclosure of vulnerability information to third parties
 - Failure to comply with data destruction requirements
3. **Intellectual Property Infringement**
 - Use of unlicensed software or tools
 - Infringement claims by third parties due to Consultant's actions
4. **Regulatory Violations**
 - Violations causing FDA enforcement action
 - HIPAA violations resulting in HHS penalties
 - Export control violations
5. **Bodily Injury or Property Damage**
 - Physical injury during social engineering testing
 - Destruction of hardware or facilities

9.3 Client Indemnification of Consultant (Safe Harbor)

Client shall indemnify, defend, and hold harmless Consultant from any claims, losses, damages, or expenses (including reasonable attorneys' fees) arising from:

- **Authorized Testing Activities:** Any good faith testing activity conducted within the agreed scope and Rules of Engagement, provided Consultant:
 - Followed the approved Statement of Work
 - Adhered to all restrictions and limitations in Section 4
 - Immediately ceased activity causing unintended disruption
 - Provided timely notice of critical findings or incidents
- **Third-Party Claims:** Claims by Client's customers, partners, or vendors alleging harm from Consultant's authorized testing activities
- **Regulatory Actions:** Government or regulatory inquiries resulting from authorized penetration testing activities

Safe Harbor Conditions: This indemnification does NOT apply if:

- Consultant acted outside the agreed scope
- Consultant violated Section 4.3 (Prohibited Activities)
- Consultant failed to follow emergency notification procedures
- Consultant's actions constituted gross negligence or willful misconduct

9.4 Consultant Indemnification of Client

Consultant shall indemnify, defend, and hold harmless Client from any claims, losses, damages, or expenses (including reasonable attorneys' fees) arising from:

- Consultant's gross negligence or willful misconduct
- Unauthorized disclosure of Client confidential information
- Intellectual property infringement by Consultant
- Breach of Section 4.3 (Prohibited Activities)
- Actions of Consultant personnel outside scope of engagement

9.5 Limitation of Consequential Damages

Neither party shall be liable to the other for any indirect, incidental, consequential, special, or punitive damages, including but not limited to:

- Lost profits or revenue
- Loss of business opportunity
- Loss of goodwill or reputation
- Cost of replacement services
- Loss or corruption of data

Exceptions: This limitation does not apply to damages arising from gross negligence, willful misconduct, or breach of confidentiality obligations.

10. INSURANCE REQUIREMENTS

10.1 Consultant Insurance

Consultant shall maintain, at its own expense, the following insurance coverage throughout the term of this Agreement:

1. Professional Liability / Errors & Omissions (E&O) Insurance

- **Minimum Coverage:** \$5,000,000 per occurrence / \$5,000,000 aggregate
- **Coverage Requirements:**
 - Cyber liability coverage included
 - Network security and privacy liability
 - Coverage for security testing and penetration testing services
 - Retroactive date prior to Agreement commencement
 - Extended reporting period (tail coverage) of minimum 3 years

2. Cyber Liability Insurance

- **Minimum Coverage:** \$3,000,000 per occurrence / \$3,000,000 aggregate
- **Coverage Requirements:**
 - First-party data breach response costs
 - Third-party liability for security failures
 - Regulatory defense and penalties
 - Business interruption coverage

3. Commercial General Liability (CGL)

- **Minimum Coverage:** \$2,000,000 per occurrence / \$4,000,000 aggregate
- **Coverage Requirements:**
 - Bodily injury and property damage
 - Personal and advertising injury
 - Client named as additional insured

4. Workers' Compensation

- Statutory limits as required by applicable state law
- Employer's liability: \$1,000,000 each accident

10.2 Proof of Insurance

Consultant shall provide Client with:

- Certificates of Insurance (ACORD 25 form or equivalent) prior to Agreement execution
- Updated certificates within thirty (30) days of any policy renewal or change
- Written notice within five (5) business days of policy cancellation or material change

All certificates shall:

- Name Client as certificate holder: Apex Pharmaceuticals LLC, 1847 BioScience Boulevard, Cambridge, MA 02142
- Include Agreement reference number
- Contain 30-day advance notice of cancellation clause
- Be issued by insurance carriers rated A- VII or better by A.M. Best

10.3 Client Insurance

Client represents that it maintains:

- Cyber liability insurance covering third-party penetration testing activities
- Professional liability insurance adequate for its operations
- General liability insurance covering its facilities

Client shall not seek recovery from Consultant's insurers for claims covered by Client's own insurance policies, except in cases of Consultant's gross negligence or willful misconduct.

10.4 Failure to Maintain Insurance

Failure to maintain required insurance coverage shall:

- Constitute a material breach of this Agreement
- Permit Client to suspend services until compliant insurance is provided
- Allow Client to terminate this Agreement with thirty (30) days written notice
- Entitle Client to withhold payment for services performed without adequate insurance

11. CONFIDENTIALITY AND NON-DISCLOSURE

11.1 Mutual Confidentiality Obligations

Each party ("Receiving Party") agrees to protect the confidential information of the other party ("Disclosing Party") with the same degree of care it uses to protect its own confidential information, but in no event less than reasonable care.

"Confidential Information" includes:

Client Confidential Information:

- Network architecture diagrams and topology maps
- System configurations and security controls
- IP addresses, hostnames, and infrastructure details
- Vulnerability information and security weaknesses
- Access credentials (temporary testing accounts)
- Security policies, procedures, and incident response plans
- Business strategies, research data, and proprietary formulations
- Employee information and organizational structure
- All information marked "Confidential," "Proprietary," or similar designation

Consultant Confidential Information:

- Testing methodologies and proprietary tools
- Pricing structures and fee schedules
- Personnel qualifications and resumes
- Exploitation techniques and custom scripts
- Client lists and business relationships

11.2 Vulnerability Disclosure Restrictions

Critical Protection: Consultant shall NOT disclose any vulnerability information, including:

- Specific vulnerabilities identified during testing
- Exploitation methods or proof-of-concept code
- System weaknesses or security gaps
- Remediation status or timelines

Exceptions - Disclosure Permitted Only:

1. **With Written Authorization:** Client provides explicit written consent for specific disclosure (e.g., responsible disclosure to vendors)
2. **To Consultant Personnel:** On strict need-to-know basis for personnel directly involved in the engagement, subject to:
 - Signed individual NDAs
 - Clear understanding of confidentiality obligations
 - Immediate termination of access upon separation
3. **Legal Compulsion:** If required by court order, subpoena, or government investigation, provided:
 - Consultant provides immediate written notice to Client (within 24 hours)
 - Consultant reasonably cooperates with Client to seek protective order
 - Disclosure limited to legally required minimum
4. **Industry Sharing (Anonymized Only):** Aggregated, anonymized vulnerability statistics for industry reports or benchmarking, provided:
 - No identifying information about Client
 - No specific system details
 - No vulnerability details that could lead to Client identification
 - Client review and approval of any publication

11.3 Term of Confidentiality

Confidentiality obligations shall survive for:

- **Vulnerability Information:** Seven (7) years from discovery date or until publicly disclosed by a source other than Consultant, whichever is later
- **Other Confidential Information:** Five (5) years from date of disclosure
- **Trade Secrets:** Indefinitely, or until no longer meeting legal definition of trade secret

11.4 Data Handling During Engagement

Captured Data:

- Consultant may collect data strictly necessary for security testing
- Maximum data retention: 10MB per engagement per system
- No collection of actual PHI, PII, financial data, or intellectual property
- Test data only: simulated, dummy, or publicly available information

Data Storage:

- All Client data stored on encrypted devices (AES-256 or equivalent)
- Storage limited to Consultant's secure, access-controlled environment
- No storage on personal devices or unapproved cloud services
- Access restricted to authorized engagement personnel only

Data Transmission:

- Encrypted transmission only (TLS 1.2 or higher)
- Reports delivered via secure file transfer or encrypted email
- Credentials transmitted via out-of-band secure method (e.g., password-protected with phone-based password sharing)

11.5 Data Destruction Policy

Post-Engagement Data Destruction:

Within thirty (30) days of final report delivery, Consultant shall:

1. Securely Delete:

- All captured network traffic
- Screenshots and evidence files
- Vulnerability scan databases
- System access logs
- Credential lists and authentication tokens
- Draft reports and working documents

2. Destruction Method:

- Electronic data: DoD 5220.22-M compliant wiping (7-pass minimum) or cryptographic erasure
- Physical media: Shredding or physical destruction
- Cloud storage: Cryptographic deletion with verification

3. Certificate of Destruction:

- Consultant shall provide written certification of data destruction
- Signed by authorized Consultant officer
- Delivered within five (5) business days of destruction completion

Retention Exceptions:

- Final delivered report: Retained per Consultant's standard retention policy (7 years minimum)
- Aggregate, anonymized metrics: Retained for benchmarking purposes
- Information required by law or regulation: Retained per legal requirements

Client Data Destruction Right: Client may request immediate data destruction at any time by written notice. Consultant shall comply within five (5) business days of receipt.

11.6 Breach Notification

In the event of unauthorized disclosure or suspected compromise of Client confidential information, Consultant shall:

- **Immediate Notice:** Notify Client within four (4) hours of discovery
- **Incident Report:** Provide detailed incident report within 24 hours including:
 - Nature and scope of disclosure
 - Data elements affected
 - Number of records or systems compromised
 - Root cause analysis
 - Remediation steps taken
 - Prevention measures implemented
- **Regulatory Assistance:** Reasonably cooperate with Client's breach notification and regulatory compliance obligations
- **Cost Responsibility:** Bear all reasonable costs of breach notification and remediation

12. TERM, RENEWAL, AND TERMINATION

12.1 Initial Term

This Agreement shall commence on **January 1, 2026** ("Effective Date") and continue for an initial period of twelve (12) months, ending on **December 31, 2026** ("Initial

Term"), unless earlier terminated in accordance with this Section 12.

12.2 Auto-Renewal Terms

This Agreement shall automatically renew for successive twelve (12) month periods ("Renewal Terms") unless either party provides written notice of non-renewal at least sixty (60) days prior to the end of the then-current term.

Auto-Renewal Conditions:

- Fees subject to annual adjustment per Section 8.5
- Scope of services remains consistent unless modified by written amendment
- All other terms and conditions remain in full effect
- Updated Statements of Work required for each Renewal Term within 30 days of renewal

Non-Renewal Notice Requirements:

- Must be in writing via certified mail or email with read receipt
- Sent to designated contacts in Section 1
- Specify effective date of termination (end of current term)

12.3 Termination for Convenience

Either party may terminate this Agreement for convenience with ninety (90) days prior written notice, provided:

If Client Terminates:

- Client pays for all services completed or in progress as of termination date
- Client pays 50% of fees for remaining scheduled engagements in current term
- Consultant delivers all completed reports within ten (10) business days

If Consultant Terminates:

- Consultant completes all engagements scheduled to commence within ninety (90) days
- Consultant provides transition assistance for up to thirty (30) days
- No early termination fees owed by Client

12.4 Termination for Cause

Either party may terminate this Agreement immediately upon written notice if the other party:

Material Breach:

- Fails to cure a material breach within thirty (30) days of written notice
- Commits repeated non-material breaches demonstrating pattern of non-compliance
- Violates confidentiality obligations under Section 11

Specific Cause Events:

Client May Terminate If Consultant:

- Fails to maintain required insurance (Section 10)
- Suffers data breach exposing Client confidential information
- Assigns personnel who fail background checks
- Violates Rules of Engagement causing material harm
- Delivers two (2) consecutive late reports without cure
- Becomes insolvent or files for bankruptcy protection

Consultant May Terminate If Client:

- Fails to pay undisputed invoices within sixty (60) days
- Repeatedly denies access to systems or personnel necessary for testing
- Fails to provide safe working environment during on-site engagements
- Makes material misrepresentations about infrastructure or scope

Termination for Cause Effects:

- Immediate cessation of services
- No additional fees owed except for completed work
- No early termination penalties
- Non-breaching party may seek damages

12.5 Obligations Upon Termination

Upon termination or expiration of this Agreement, regardless of reason:

Within 5 Business Days:

- Consultant shall return or destroy all Client confidential information per Section 11.5
- Consultant shall disable all test accounts and access credentials
- Consultant shall deliver all completed and draft reports
- Client shall pay all undisputed invoices for services rendered

Within 30 Days:

- Consultant shall provide Certificate of Destruction (Section 11.5.3)
- Consultant shall deliver all vulnerability tracking data in agreed format
- Client shall return Consultant confidential information or confirm destruction

- Final true-up payment for prorated services

Surviving Provisions: The following sections shall survive termination or expiration:

- Section 9 (Liability and Indemnification): 3 years
- Section 10 (Insurance): 3 years for claims related to prior services
- Section 11 (Confidentiality): Per Section 11.3 timeframes
- Section 13 (Intellectual Property): Indefinitely
- Section 17 (Dispute Resolution): Indefinitely for pre-termination disputes
- Section 19 (General Provisions): As applicable

12.6 Transition Assistance

Upon termination by either party, Consultant agrees to provide reasonable transition assistance for up to sixty (60) days, including:

- Knowledge transfer sessions (up to 10 hours, no charge)
- Documentation of testing history and methodologies
- Vulnerability tracking database handover
- Recommendations for alternative service providers
- Introduction meetings with replacement vendor (if requested)

Transition assistance beyond 60 days or 10 hours billed at standard hourly rates with 50% discount.

13. INTELLECTUAL PROPERTY RIGHTS

13.1 Client Pre-Existing IP

Client retains all right, title, and interest in and to:

- All Client systems, networks, and infrastructure
- Client proprietary technology and trade secrets
- Client data, documentation, and business information
- Client trademarks, logos, and brand elements

Nothing in this Agreement transfers any ownership rights in Client IP to Consultant.

13.2 Consultant Pre-Existing IP

Consultant retains all right, title, and interest in and to:

- Proprietary testing methodologies and frameworks
- Custom tools and scripts developed prior to this Agreement
- Consultant's expertise, know-how, and techniques
- Consultant trademarks, logos, and brand elements

Nothing in this Agreement transfers any ownership rights in Consultant IP to Client.

13.3 Work Product Ownership

Reports and Deliverables:

- Client owns all reports, findings documentation, and deliverables created specifically for Client under this Agreement
- Client may use, reproduce, modify, and distribute reports internally without restriction
- Consultant grants Client a perpetual, irrevocable, worldwide, royalty-free license to use reports

Tools and Scripts Developed During Engagement:

- Custom exploitation scripts created specifically for Client's environment: Joint ownership
- Generic tools applicable to multiple clients: Consultant retains ownership
- Client receives non-exclusive license to use custom scripts for internal security testing only

13.4 Residual Knowledge

Consultant may retain and use residual knowledge gained from this engagement, including:

- General security testing experience and expertise
- Understanding of common vulnerability patterns
- Non-confidential technical knowledge

Provided such use does not:

- Violate confidentiality obligations in Section 11
- Disclose Client-specific vulnerability information
- Incorporate Client confidential information

13.5 Use of Client Name and Logo

Default Prohibition: Consultant shall NOT use Client's name, logo, trademarks, or identify Client as a customer in marketing materials, case studies, client lists, or public communications without prior written consent.

Permitted Use - With Consent: Client may grant written consent for specific uses, such as:

- Inclusion in client list (name only, no details)
- Anonymous case study (no identifying information)
- Industry presentations (aggregated, anonymized data)

Consent Requirements:

- Must be in writing from Client's General Counsel
 - Specify approved uses and limitations
 - Subject to Client review and approval of specific materials
 - Revocable at any time with 30 days notice
-

14. COMPLIANCE AND REGULATORY REQUIREMENTS

14.1 Regulatory Compliance

Consultant acknowledges that Client operates in a highly regulated industry and agrees to comply with all applicable laws, regulations, and industry standards, including but not limited to:

Healthcare and Pharmaceutical Regulations:

- Health Insurance Portability and Accountability Act (HIPAA) and HITECH Act
- FDA regulations including 21 CFR Part 11 (Electronic Records; Electronic Signatures)
- Good Manufacturing Practice (GMP), Good Laboratory Practice (GLP), Good Clinical Practice (GCP)
- European Union General Data Protection Regulation (GDPR) for EU facilities
- Personal Information Protection and Electronic Documents Act (PIPEDA) for Canadian operations

Information Security Standards:

- NIST Cybersecurity Framework
- ISO/IEC 27001 Information Security Management
- NIST SP 800-53 Security and Privacy Controls
- OWASP Testing Guide v4.2 or current version

Export Control:

- U.S. Export Administration Regulations (EAR)
- International Traffic in Arms Regulations (ITAR)
- Consultant shall not test from embargoed countries or employ foreign nationals subject to restrictions

14.2 HIPAA Business Associate Requirements

To the extent Consultant may access Protected Health Information (PHI) as defined under HIPAA:

Prohibited PHI Access:

- Consultant shall NOT intentionally access actual patient PHI during testing
- Any inadvertent PHI access must be immediately reported per Section 11.6
- Consultant shall not use or disclose PHI except as required to perform services

Business Associate Agreement (BAA):

- Parties shall execute a separate HIPAA Business Associate Agreement
- BAA terms incorporated by reference into this Agreement
- In the event of conflict, BAA terms control for PHI-related matters

14.3 FDA 21 CFR Part 11 Compliance

For testing involving systems subject to FDA 21 CFR Part 11:

- Consultant shall maintain audit trail documentation of all testing activities
- Consultant shall validate that testing does not corrupt electronic signatures
- Consultant shall ensure testing does not compromise audit trail integrity
- Consultant shall receive and document training on 21 CFR Part 11 requirements prior to testing

14.4 Data Privacy Compliance

GDPR Compliance (EU Facilities):

- Consultant acts as Data Processor for any EU personal data accessed
- Client is Data Controller responsible for lawful basis of processing
- Data Processing Agreement (DPA) shall be executed separately
- Consultant shall implement appropriate technical and organizational measures
- Consultant shall assist with Data Subject Access Requests (DSARs) if required

Data Residency:

- Data collected from Basel, London facilities shall not be transferred outside EU without appropriate safeguards (SCCs or adequacy decision)
- Singapore facility data subject to Singapore Personal Data Protection Act (PDPA)
- Japan facility data subject to Act on Protection of Personal Information (APPI)

14.5 Audit Rights

Client reserves the right to audit Consultant's compliance with this Agreement, including:

Audit Scope:

- Compliance with confidentiality and data protection obligations
- Security controls protecting Client data
- Personnel background check records
- Insurance coverage maintenance
- Data destruction procedures

Audit Process:

- Minimum thirty (30) days advance written notice
- During normal business hours
- No more than once per year (except for cause)
- Consultant pays for audit if material non-compliance found

15. REPRESENTATIONS AND WARRANTIES

15.1 Consultant Representations and Warranties

Consultant represents, warrants, and covenants that:

Authority and Legal Compliance:

- Consultant is duly organized, validly existing, and in good standing
- Consultant has full authority to enter into and perform this Agreement
- Services shall be performed in compliance with all applicable laws and regulations
- Consultant holds all necessary licenses and permits to perform services

Service Quality:

- Services shall be performed in a professional and workmanlike manner
- Services shall conform to industry standards and best practices
- Personnel assigned possess necessary skills, qualifications, and certifications
- Testing methodologies comply with OWASP, NIST, and PTES standards

Personnel:

- All personnel have undergone and passed required background checks
- Personnel maintain current and valid professional certifications
- No personnel are subject to disciplinary action by certification bodies
- Personnel are employees or approved contractors of Consultant (no unauthorized subcontracting)

Tools and Licenses:

- All tools and software used are properly licensed
- No tools contain malicious code or unauthorized functionality
- Tools have been vetted for safety and reliability
- Consultant has right to use all tools in commercial engagements

No Conflicts:

- Consultant has no conflicts of interest affecting its performance
- Consultant does not represent competing interests
- Consultant has disclosed all potential conflicts prior to engagement

Insurance:

- All insurance representations in Section 10 are true and accurate
- Insurance policies are in full force and effect
- No claims that would impair coverage have been made
- Consultant has no knowledge of circumstances that would result in cancellation

15.2 Client Representations and Warranties

Client represents, warrants, and covenants that:

Authority:

- Client has authority to engage Consultant for testing services
- Client has authority to grant access to all systems within scope
- Execution of this Agreement approved by appropriate Client authority

System Ownership:

- Client owns or has authorization to test all systems within scope
- No third-party systems included without proper authorization
- Client has obtained necessary consents from data subjects where required

Accurate Information:

- All information provided about infrastructure and scope is accurate

- Client has disclosed all material risks and constraints
- Asset inventory provided is complete and current

Safe Environment:

- Client shall provide reasonably safe working environment for on-site testing
- Client has disclosed all known hazards at testing locations
- Client shall not direct Consultant to engage in illegal activities

15.3 Disclaimer of Warranties

EXCEPT AS EXPRESSLY PROVIDED IN SECTION 15.1, CONSULTANT MAKES NO WARRANTIES, EXPRESS OR IMPLIED, INCLUDING:

NO GUARANTEE OF FINDING ALL VULNERABILITIES:

- Services are best-effort and point-in-time assessments
- Absence of findings does not guarantee complete security
- New vulnerabilities may emerge after testing completion

NO IMPLIED WARRANTIES:

- NO WARRANTY OF MERCHANTABILITY
- NO WARRANTY OF FITNESS FOR PARTICULAR PURPOSE
- NO WARRANTY OF NON-INFRINGEMENT
- NO WARRANTY OF TITLE

NO GUARANTEE OF OUTCOMES:

- No guarantee that Client will achieve compliance certification
- No guarantee that Client will pass third-party audits
- No guarantee of specific security posture improvement

Limitations of Testing:

- Testing represents snapshot of security posture at time of engagement
- Threat landscape constantly evolves
- Zero-day vulnerabilities may exist but be undiscovered
- Human error and social engineering risks cannot be completely eliminated

Client acknowledges that security testing cannot identify all possible vulnerabilities and that absolute security is unattainable.

16. FORCE MAJEURE

16.1 Force Majeure Events

Neither party shall be liable for delays or failure to perform obligations under this Agreement due to Force Majeure Events beyond its reasonable control, including:

- Acts of God (earthquakes, floods, fires, hurricanes, pandemics)
- War, terrorism, civil unrest, or riots
- Government actions, orders, or regulations preventing performance
- Cyberattacks affecting Consultant's or Client's infrastructure
- Utility failures (power outages, internet service disruptions)
- Labor disputes (strikes, lockouts) not involving the party's own employees
- Supplier failures for essential services not reasonably preventable

16.2 Notice and Mitigation

Notice Requirement: A party claiming Force Majeure must:

- Provide written notice within five (5) business days of Force Majeure event
- Describe nature and expected duration of delay
- Specify obligations affected
- Provide updates every fifteen (15) days while Force Majeure continues

Mitigation Obligation: The affected party must:

- Use commercially reasonable efforts to mitigate impact
- Resume performance as soon as reasonably possible
- Utilize alternate resources or methods if available
- Minimize extent and duration of delay

16.3 Rights During Force Majeure

Suspension of Obligations:

- Affected obligations suspended during Force Majeure
- Performance deadlines extended by duration of Force Majeure plus reasonable recovery period
- Payment obligations suspended proportionately for non-delivered services

Termination Rights: If Force Majeure continues for more than sixty (60) consecutive days:

- Either party may terminate affected engagement(s) upon written notice
- If Force Majeure affects entire Agreement, either party may terminate Agreement

- Client pays only for services completed prior to Force Majeure
- No early termination penalties apply

16.4 Exceptions

Force Majeure does NOT excuse:

- Payment obligations for services already rendered
 - Confidentiality obligations
 - Data destruction obligations
 - Insurance maintenance requirements
-

17. DISPUTE RESOLUTION

17.1 Informal Resolution

Prior to initiating formal dispute resolution, parties agree to attempt good faith informal resolution:

Negotiation Process:

1. Written notice describing dispute in detail delivered to other party's primary contact
2. Senior executives meet within fifteen (15) days (Dr. Vásquez for Client, Sarah Mitchell for Consultant)
3. Executives negotiate in good faith for thirty (30) days
4. If unresolved, parties may proceed to mediation

17.2 Mediation

Mandatory Mediation:

- If informal negotiation fails, parties shall participate in mediation before filing litigation or arbitration
- Mediation shall occur in Boston, Massachusetts
- Parties shall mutually select mediator from JAMS or AAA panel within ten (10) days
- If parties cannot agree, mediator selected by JAMS/AAA
- Each party bears its own costs; mediator fees split equally

Mediation Timeline:

- Mediation shall commence within thirty (30) days of mediator selection
- Mediation session limited to two (2) full business days unless extended by mutual consent
- If unresolved after mediation, parties may proceed to arbitration or litigation

17.3 Arbitration

Binding Arbitration - For Disputes Exceeding \$250,000:

- Disputes involving amounts greater than \$250,000 shall be resolved by binding arbitration
- Arbitration conducted under Commercial Arbitration Rules of American Arbitration Association (AAA)
- Seat of arbitration: Boston, Massachusetts
- Arbitrator selection: Single arbitrator mutually selected, or appointed by AAA if no agreement within fifteen (15) days
- Arbitrator must have minimum 10 years experience in technology contracts and cybersecurity matters

Arbitration Procedures:

- Discovery permitted consistent with AAA rules (limited scope)
- Hearing conducted within six (6) months of arbitrator appointment
- Arbitrator shall issue written decision with findings of fact and conclusions of law
- Arbitrator's decision is final and binding
- Judgment on award may be entered in any court with jurisdiction

Costs:

- Each party bears its own legal fees and costs
- Arbitrator fees and AAA administrative costs split equally unless arbitrator awards otherwise

17.4 Litigation - For Disputes Under \$250,000

Court Jurisdiction: Disputes involving amounts of \$250,000 or less may be brought in state or federal courts located in:

- **Primary Venue:** Massachusetts (Suffolk County Superior Court or U.S. District Court for the District of Massachusetts)
- Parties consent to exclusive jurisdiction and venue in these courts
- Parties waive any objection to venue or inconvenient forum

17.5 Equitable Relief

Notwithstanding Sections 17.2-17.4, either party may seek equitable relief (injunction, specific performance, temporary restraining order) in any court of competent jurisdiction for:

- Breach of confidentiality obligations
- Unauthorized use of intellectual property
- Violations requiring immediate action to prevent irreparable harm

Such equitable relief may be sought without exhausting informal resolution, mediation, or arbitration.

17.6 Attorneys' Fees

In any dispute resolution proceeding:

- **Substantially Prevailing Party:** Party prevailing on significant majority of issues may recover reasonable attorneys' fees and costs
- **Frivolous Claims:** Party bringing claim found to be frivolous or in bad faith shall pay other party's fees and costs
- **Fee Awards:** Subject to mediator recommendation, arbitrator decision, or court determination

18. MISCELLANEOUS PROVISIONS

18.1 Independent Contractor

Consultant is an independent contractor, not an employee, agent, partner, or joint venturer of Client. Consultant:

- Has no authority to bind Client or make commitments on Client's behalf
- Is responsible for all taxes, insurance, and benefits for its personnel
- Controls means and methods of performing services
- Provides own tools, equipment, and workspace

18.2 Assignment

Prohibition on Assignment: Neither party may assign this Agreement without prior written consent of the other party, except:

Permitted Assignments:

- Assignment to affiliate or subsidiary controlling, controlled by, or under common control with assigning party
- Assignment in connection with merger, acquisition, or sale of substantially all assets
- Assignment to successor entity resulting from corporate reorganization

Effect of Permitted Assignment:

- Assigning party remains liable for obligations unless non-assigning party releases in writing
- Assignee must assume all obligations in writing
- Assigning party provides written notice within fifteen (15) days

Subcontracting: Consultant may subcontract portions of services only with:

- Prior written approval from Client (not unreasonably withheld)
- Subcontractors meeting all qualifications in Section 5
- Consultant remaining fully liable for subcontractor performance
- Subcontractors bound by all confidentiality and security obligations

18.3 Entire Agreement

This Agreement, including all exhibits, schedules, and referenced documents, constitutes the entire agreement between parties regarding the subject matter and supersedes all prior:

- Negotiations and discussions
- Proposals and quotes
- Agreements and understandings (written or oral)
- Course of dealing or trade usage

Integrated Documents: The following are incorporated by reference:

- Statements of Work for each engagement (executed separately)
- HIPAA Business Associate Agreement (if executed)
- Data Processing Agreement for GDPR compliance (if executed)

18.4 Amendments

This Agreement may be amended only by written document signed by authorized representatives of both parties. Email exchanges shall not constitute amendments unless explicitly stated and confirmed by both parties.

SOW Amendments:

- Minor scope changes to individual Statements of Work may be approved via email by designated contacts in Section 1
- Major scope changes or fee adjustments require formal written amendment

18.5 Waiver

Failure or delay by either party to enforce any provision shall not constitute waiver of:

- That provision
- Any other provision
- Right to enforce provision in future

Waiver effective only if in writing and signed by party granting waiver. Waiver of one breach does not waive subsequent breaches.

18.6 Severability

If any provision is held invalid, illegal, or unenforceable:

- Remaining provisions remain in full force and effect
- Invalid provision shall be modified to minimum extent necessary to make enforceable while preserving intent
- If modification impossible, provision shall be severed

18.7 Notices

All notices required or permitted under this Agreement shall be in writing and delivered to addresses in Section 1 via:

Acceptable Delivery Methods:

- **Email:** To designated contact email addresses (acceptable for routine notices)
- **Certified Mail:** Return receipt requested (required for termination notices)
- **Overnight Courier:** FedEx, UPS, DHL with signature confirmation
- **Personal Delivery:** With written receipt

Notice Effective:

- Email: Upon transmission if during business hours, otherwise next business day
- Mail/Courier: Upon receipt or refusal of delivery
- Personal Delivery: Upon delivery

Change of Address: Party may change notice address by providing fifteen (15) days advance written notice.

18.8 Governing Law

This Agreement shall be governed by and construed in accordance with the laws of the **Commonwealth of Massachusetts**, without regard to its conflicts of law principles.

Federal Law:

- Computer Fraud and Abuse Act (CFAA) 18 U.S.C. § 1030 - Parties acknowledge authorized access under this Agreement
- Electronic Communications Privacy Act (ECPA)
- Relevant federal regulations governing pharmaceutical industry

18.9 Counterparts and Electronic Signatures

This Agreement may be:

- Executed in counterparts, each constituting an original
- Signed electronically with same legal effect as manual signature
- Transmitted via PDF or electronic signature platform (DocuSign, Adobe Sign)

18.10 Publicity and Press Releases

Neither party shall issue press releases, public announcements, or marketing materials mentioning the other party without:

- Prior written approval of content
- Approval by authorized representative
- Right to review and approve any subsequent modifications

Exception: Legally required disclosures (subject to advance notice if permitted by law).

18.11 Third-Party Beneficiaries

This Agreement is for sole benefit of parties and their permitted successors and assigns. No third party has any right to enforce or benefit from any provision of this Agreement.

18.12 Survival

The following sections survive termination or expiration with durations specified:

- Section 8 (Financial Terms): Until all payments made - Indefinite
- Section 9 (Liability): 3 years from termination
- Section 10 (Insurance): 3 years from termination (for prior claims)
- Section 11 (Confidentiality): Per Section 11.3 timeframes (5-7 years)
- Section 13 (Intellectual Property): Indefinite
- Section 17 (Dispute Resolution): Indefinite
- Section 18 (Miscellaneous): As applicable

18.13 Relationship of Parties

Nothing in this Agreement creates:

- Partnership or joint venture
- Employer-employee relationship
- Agency relationship (except as expressly authorized)
- Franchise relationship

18.14 Compliance with Laws

Each party shall comply with all applicable federal, state, local, and international laws, regulations, and ordinances in performing its obligations under this Agreement, including:

- Export control laws
- Anti-corruption laws (FCPA, UK Bribery Act)
- Data protection and privacy laws
- Securities laws and regulations
- Employment and labor laws
- Environmental laws

18.15 Language

This Agreement is executed in English. Any translation provided for convenience only; English version controls in event of discrepancy.

19. EXHIBITS AND SCHEDULES

The following exhibits and schedules are attached and incorporated into this Agreement:

EXHIBIT A: Detailed IP Address Ranges and Asset Inventory **EXHIBIT B:** Approved Tools and Prohibited Tools List **EXHIBIT C:** Report Template and Format Requirements **EXHIBIT D:** Statement of Work Template **EXHIBIT E:** Certificate of Insurance Requirements **EXHIBIT F:** Background Check Standards and Procedures **EXHIBIT G:** Data Classification and Handling Matrix **EXHIBIT H:** Incident Response and Escalation Procedures **EXHIBIT I:** Vulnerability Tracking Database Schema **EXHIBIT J:** HIPAA Business Associate Agreement (if applicable) **EXHIBIT K:** EU Standard Contractual Clauses (if applicable)

SIGNATURE PAGE

IN WITNESS WHEREOF, the parties have executed this Master Services Agreement as of the date first written above.

APEX PHARMACEUTICALS LLC

By: _____

Name: Dr. Richard Wolcott

Title: Chief Executive Officer

Date: _____

By: _____

Name: Jennifer Park

Title: General Counsel

Date: _____

CYBERSHIELD SECURITY CONSULTANTS LTD.

By: _____

Name: Thomas Blackwell

Title: Chief Executive Officer

Date: _____

By: _____

Name: Catherine Lewis

Title: Chief Legal Officer

Date: _____